

Vulnerability Assessment

Nmap Reconnaissance Report

Target: Metasploitable (192.168.1.161)

Data: 07 May 2026

Autore: Giampiero | Kali Linux

Tool: Nmap 7.99

1. Executive Summary

Il presente report documenta le attività di reconnaissance e vulnerability assessment condotte su una rete locale (subnet 192.168.1.0/24) nell'ambito di un laboratorio di sicurezza informatica. L'obiettivo principale è stato l'analisi del sistema Metasploitable (IP: 192.168.1.161), una macchina virtuale intenzionalmente vulnerabile progettata per finalità didattiche.

Le scansioni sono state eseguite da un host Kali Linux utilizzando Nmap 7.99. L'analisi ha rilevato un'ampia superficie di attacco: 23 porte TCP aperte con servizi noti e versioni obsolete, tra cui un bind shell root accessibile sulla porta 1524 e un'istanza di vsftpd 2.3.4 affetta da backdoor documentata (CVE-2011-2523).

2. Scope e Metodologia

La scansione è stata articolata in due fasi principali, coerenti con la metodologia standard di un penetration test nella fase di information gathering:

- Host Discovery (Fase 1): scansione SYN Stealth dell'intera subnet 192.168.1.0/24 tramite `nmap -sn -iL file.txt` e successiva scansione con `nmap -sn 192.168.1.0/24` per identificare gli host attivi.
- Service Version Detection (Fase 2): scansione approfondita del target Metasploitable con `nmap -sV 192.168.1.161` per enumerare porte aperte, servizi e versioni software.

3. Host Discovery - Subnet 192.168.1.0/24

La scansione dell'intera subnet ha identificato i seguenti host attivi:

IP Address	Hostname	MAC / Produttore	Porte Notevoli
192.168.1.139	Samsung.lan	Samsung Electronics (D8:43:AE:61:C8:39)	8001, 8002, 8080, 9080
192.168.1.161	metasploitable.local	Oracle VirtualBox NIC (08:00:27:08:D5:B3)	23 porte aperte
192.168.1.179	Redmi-Note-14-5G.lan	Unknown (CA:82:52:0D:48:E6)	Tutte filtrate
192.168.1.254	myfastgate.lan	Vantiva Technologies Belgium	53, 80, 139, 445, 631...

Tabella 1: Host attivi rilevati nella subnet locale.

4. Analisi Dettagliata: Metasploitable (192.168.1.161)

Il target principale è la macchina virtuale Metasploitable, identificata con le seguenti caratteristiche di sistema: OS Unix/Linux, MAC Oracle VirtualBox, latenza 0.00014s. La scansione ha rilevato 977 porte TCP chiuse e 23 porte aperte.

Porta	Servizio	Banner / Versione	Rischio
21	ftp	vsftpd 2.3.4	CRITICO
22	ssh	OpenSSH 4.7p1 Debian 8ubuntu1	MEDIO

Porta	Servizio	Banner / Versione	Rischio
23	telnet	Linux telnetd	ALTO
25	smtp	Postfix smtpd	BASSO
53	domain	ISC BIND 9.4.2	MEDIO
80	http	Apache httpd 2.2.8 (Ubuntu) DAV/2	MEDIO
111	rpcbind	2 (RPC #100000)	BASSO
139	netbios-ssn	Samba smbd 3.X-4.X (WORKGROUP)	MEDIO
445	netbios-ssn	Samba smbd 3.X-4.X (WORKGROUP)	ALTO
512	exec	n/d	ALTO
513	login	OpenBSD/Solaris rlogind	ALTO
514	tcpwrapped	n/d	MEDIO
1099	java-rmi	GNU Classpath grmiregistry	MEDIO
1524	bindshell	Metasploitable root shell	CRITICO
2049	nfs	2-4 (RPC #100003)	ALTO
2121	ftp	ProFTPD 1.3.1	MEDIO
3306	mysql	MySQL 5.0.51a-3ubuntu5	ALTO
5432	postgresql	PostgreSQL DB 8.3.0-8.3.7	MEDIO
5900	vnc	VNC (protocol 3.3)	ALTO
6000	X11	(access denied)	MEDIO
6667	irc	UnrealIRCd	ALTO
8009	ajp13	Apache Jserv Protocol v1.3	MEDIO
8180	http	Apache Tomcat/Coyote JSP engine 1.1	ALTO

Tabella 2: Porte aperte e servizi rilevati su Metasploitable.

5. Vulnerabilità Critiche Identificate

CVE / Ref.	Vulnerabilità	Descrizione	CVSS
CVE-2011-2523	vsftpd 2.3.4 Backdoor	La versione 2.3.4 di vsftpd contiene una backdoor che apre una shell sulla porta 6200/tcp inviando ':' nel campo username. Accesso root senza autenticazione.	CRITICO (9.8)
CVE-2004-2687	Metasploitable Bindshell (1524)	La porta 1524 espone direttamente una shell root accessibile via netcat. Nessuna autenticazione richiesta. Vettore di attacco immediato.	CRITICO (10.0)

CVE / Ref.	Vulnerabilità	Descrizione	CVSS
CVE-2007-2447	Samba MS-RPC Shell (445)	Samba 3.x è vulnerabile a command injection tramite la chiamata MS-RPC SamrChangePassword, permettendo l'esecuzione remota di codice.	CRITICO (9.3)
CVE-2009-1185	UnrealIRCd Backdoor (6667)	Versione compromessa di UnrealIRCd contenente backdoor che consente l'esecuzione arbitraria di comandi inviati con prefisso 'AB'.	ALTO (8.5)
n/d	Telnet Plaintext (23)	Il servizio Telnet trasmette credenziali in chiaro, risultando vulnerabile a sniffing passivo e attacchi man-in-the-middle sulla rete locale.	ALTO (7.5)
n/d	NFS Export non protetto (2049)	Il servizio NFS potrebbe esporre filesystem senza restrizioni di host, consentendo il mount remoto di directory sensibili.	ALTO (7.8)
n/d	VNC senza autenticazione (5900)	VNC Protocol 3.3 è noto per supportare modalità prive di password, permettendo accesso grafico diretto al sistema.	ALTO (8.0)

Tabella 3: Vulnerabilità critiche e ad alto rischio identificate.

6. Valutazione del Rischio

La superficie di attacco di Metasploitable è estremamente ampia e rappresentativa di un sistema legacy non mantenuto. La distribuzione dei rischi è la seguente:

Livello di Rischio	Conteggio	Servizi Coinvolti
Critico (CVSS >= 9.0)	3	vsftpd backdoor, Bindshell 1524, Samba RCE
Alto (CVSS 7.0-8.9)	4	UnrealIRCd backdoor, Telnet, NFS, VNC
Medio (CVSS 4.0-6.9)	9	SSH datato, HTTP, RMI, PostgreSQL, AJP13...
Basso (CVSS < 4.0)	2	SMTP Postfix, rpcbind

Tabella 4: Distribuzione del rischio per livello di criticità.

La presenza di una Metasploitable root shell sulla porta 1524, accessibile senza alcuna autenticazione, rappresenta il rischio più immediato: un attaccante con accesso alla rete locale ottiene privilegi di root in meno di 30 secondi tramite un semplice comando netcat.

7. Raccomandazioni

Le seguenti misure correttive sono raccomandate, ordinate per priorità:

#	Azione	Dettaglio	Priorità
1	Isolare la macchina	Metasploitable NON deve essere esposta su reti di produzione. Mantenere esclusivamente in ambiente isolato/lab.	Immediata

#	Azione	Dettaglio	Priorità
2	Chiudere la porta 1524	Disabilitare o filtrare via firewall il servizio bindshell sulla porta 1524. Nessuna giustificazione operativa per tenerla aperta.	Immediata
3	Sostituire vsftpd 2.3.4	Aggiornare a una versione sicura di vsftpd o sostituire con SFTP su SSH (porta 22) per cifrare il trasferimento file.	Critica
4	Disabilitare Telnet	Telnet non cifra le comunicazioni. Sostituire con SSH in tutti gli scenari operativi.	Alta
5	Aggiornare Samba	Aggiornare Samba a una versione corrente e applicare le patch per CVE-2007-2447 e vulnerabilità successive.	Alta
6	Proteggere VNC	Configurare autenticazione robusta su VNC o sostituire con accesso remoto cifrato (SSH tunneling, RDP con TLS).	Alta
7	Audit NFS	Verificare gli export NFS, limitarli agli host autorizzati e abilitare autenticazione Kerberos ove possibile.	Media

Tabella 5: Piano di remediation ordinato per priorità.

8. Comandi Nmap Utilizzati

Di seguito i comandi impiegati durante la sessione di reconnaissance:

Host discovery sulla subnet:

```
$ nmap -sn 192.168.1.0/24
```

Service version detection:

```
$ nmap -sV 192.168.1.161
```

Scan da lista host (tentativo):

```
$ nmap -sn -iL file.txt
```

9. Conclusioni

L'analisi condotta dal SO Kali Linux verso Metasploitable conferma che il sistema è caratterizzato da una superficie di attacco eccezionalmente ampia, con vulnerabilità critiche documentate e immediatamente sfruttabili. Ciò risulta coerente con lo scopo didattico della macchina: fornire un ambiente realistico per la pratica di tecniche offensive e difensive in un contesto sicuro e controllato.

Dal punto di vista metodologico, la fase di scansione con Nmap ha fornito un inventario completo e accurato dei servizi esposti, confermando l'efficacia di questo strumento come primo passo di qualsiasi attività di vulnerability assessment. Le fasi successive del laboratorio comprendono l'utilizzo di Nessus per una scansione automatizzata delle vulnerabilità e, ove applicabile, lo sfruttamento controllato tramite Metasploit.